

Mapeo Preguntas-Requisitos Normativos

La siguiente tabla resume el alineamiento de cada bloque/pregunta con principales marcos: NIS2 / NIS360 (ENISA), ENS, ISO 27001, NIST CSF / RMF, DORA y otros relevantes en España.[web:9][web:12][web:13][web:5]

ID Pregunta	Bloque / Tema	NIS2 / NIS360	ENS / ISO 27001	NIST CSF / RMF	DORA / Sectorial	Comentario
P1.1.1	Estrategia de ciberseguridad	Art. 21 NIS2 (gestión de riesgos)	ENS org.2, ISO 27001 A.5 (políticas)	CSF Govern (GV-1), RMF Prepare	DORA Art. 5 (estrategia TIC)	Estrategia aprobada por órgano de gobierno.
P1.1.2	Alineamiento con negocio / ERM	NIS2 gobernanza	ISO 27001 A.5, A.6	CSF Govern (apetito de riesgo)	DORA gobierno TIC	Integra ciberseguridad en estrategia empresarial.
P1.1.3	Apetito de riesgo de ciberseguridad	NIS2 obligaciones gerenciales	ISO 31000, ISO 27005	RMF Prepare / Categorize	Basilea / normativa financiera	Clave para priorización de controles.
P1.2.1	Responsabilidad ejecutiva	Art. 20 NIS2 (responsabilidad)	ENS org.1	CSF Govern (roles)	DORA responsabilidad alta dirección	Define quién responde ante incidentes.
P1.2.2	Rol del CISO	NIS2 y DORA gobernanza	Buenas prácticas ISO 27001	CSF Govern	DORA funciones de gestión TIC	Independencia y escalado.
P1.2.3	Comités de ciberseguridad	NIS2 gestión organizativa	ENS org.1, org.2	CSF Govern	DORA gobierno interno	Coordinación transversal.
P1.3.1	Cuadro de mando de ciberseguridad	NIS360 métricas	ISO 27001 A.5, A.9	CSF Identify / Govern	DORA reporting interno	Métricas integradas.
P1.3.2	Frecuencia de reporte al consejo	NIS2, DORA	ENS org.1	CSF Govern	Revisión periódica de riesgos	Supervisión formal.
P2.1.1	Metodología de riesgos	Art. 21 NIS2	ISO 27005, ISO 31000	NIST RMF	DORA gestión de riesgos TIC	Método estructurado.
P2.1.2	Alcance de riesgos (TI/OT/terceros)	NIS2 operadores críticos	ENS op.1, op.2	CSF Identify	DORA cadena de suministro	Cobertura integral.
P2.2.1	Frecuencia del análisis de riesgos	NIS2 gestión continua	ISO 27001 6.1, 9.2	RMF Monitor	DORA revisión periódica	Ciclo de vida.

P2.2.2	Nivel de cuantificación de riesgos	NIS360 madurez	ISO 27005	CSF Govern	Supervisión financiera	Modelos cuantitativos.
P2.3.1	Identificación de servicios críticos	NIS2, NIS360 criticidad	ENS categorización	CSF Identify	DORA servicios críticos financieros	Clave para priorización.
P2.3.2	Priorización de inversiones	NIS2, DORA	ISO 27001 planificación	CSF Govern	DORA planificación inversiones TIC	ROI y riesgo.
P3.1.1	Marcos normativos aplicables	NIS2, ENS, ISO, RGPD, DORA	ENS, ISO 27001	Referencia cruzada	Varios	Inventario regulatorio.
P3.1.2	Nivel de cumplimiento	NIS2 requisitos	ENS, ISO 27001	CSF Protect / Detect / Respond	DORA cumplimiento operativo	Grado de adherencia.
P3.2.1	Inventario de controles	NIS2 medidas técnicas y organizativas	ENS, ISO 27001 A.5–A.8	CSF Protect	Control framework DORA	Base del GRC.
P3.2.2	Frecuencia de revisión de controles	NIS2 supervisión	ISO 27001 9.1–9.3	RMF Monitor	DORA monitorización continua	Ciclo de mejora.
P4.1.1	Madurez IAM / PAM	NIS2, NIS360 (identidad)	ENS medidas de acceso, ISO 27001 A.9	CSF Protect (PR.AC)	Control de accesos críticos	Núcleo Zero Trust.
P4.1.2	Cobertura MFA	NIS2 requisitos técnicos	ENS, ISO 27001 A.9	CSF Protect	DORA autenticación reforzada	Autenticación robusta.
P4.2.1	Arquitectura de red	NIS2 medidas técnicas	ENS op.2, ISO 27001 A.8–A.13	CSF Protect	Infraestructura resiliente	Segmentación / Zero Trust.
P4.2.2	Uso de ZTNA / SSE / SASE	NIS360 capacidades modernas	Buenas prácticas ENS / ISO	CSF Protect / Detect	DORA continuidad	Enfoque moderno de acceso.
P4.3.1	Protección de datos sensibles	NIS2, RGPD	ENS, ISO 27001 A.8, A.10	CSF Protect	RGPD, sectorial	DLP / cifrado.

P4.3.2	SOC, SIEM, EDR/XDR	NIS2, NIS360 detección	ENS, ISO 27001 A.12–A.16	CSF Detect / Respond	DORA detección incidentes	Madurez operativa.
P5.1.1	Planes de respuesta a incidentes	Art. 23 NIS2	ENS, ISO 27035	CSF Respond	DORA planes de contingencia	Preparación .
P5.1.2	BCP/DRP con ciberincidentes	NIS2 resiliencia	ISO 22301, ENS	CSF Recover	DORA resiliencia operativa	Continuidad .
P6.1.1-3	Presupuesto , IGM y ROI	NIS2 medidas proporcionadas	Gestión financiera de controles	CSF Govern	DORA planificación de recursos	Eficiencia económica.
P7.1.1	Formación y concienciación	NIS2 obligaciones del personal	ISO 27001 A.6, A.7	CSF Protect (PR.AT)	DORA, ENS formación	Cultura.
P7.1.2	Riesgos de terceros	NIS2 cadena de suministro	ISO 27001 A.15	CSF Identify / Protect	DORA proveedores TIC	Terceros críticos.

Nota: El mapeo es orientativo y no sustituye la interpretación jurídica específica. Sirve como guía para vincular los resultados de la encuesta con programas de cumplimiento y mejora.